

Proyecto de Fin de Maestría

Diseño e Implementación de un Plan de Respuesta a Incidentes (IRP)

Especializado para la Plataforma Canvas y Servicios de
Autenticación de la Universidad Digital de las Américas
(UDA)

Autor

Luis Alberto Vargas González

Asesor

José de Jesús García
Camarena

Programa

Maestría en Ciberseguridad Online
UAG / Arizona State University

Contexto y Planteamiento del Problema



Contexto

Infraestructura Cloud

Institución educativa **100% online** con más de **25,000 estudiantes**.

Soportada íntegramente en **Amazon Web Services (AWS)**.



Activos Críticos

Sistemas Core

- **Sistema LMS Canvas** para gestión de clases.
- **Portal de acceso centralizado (SSO)**.



Problema

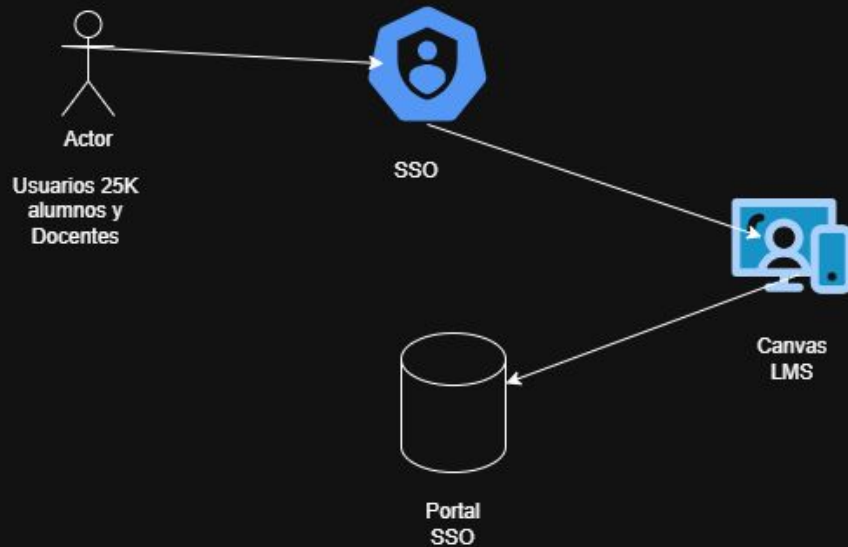
Ausencia de Protocolos

Falta de procesos formales ante anomalías.

45 a 90 min

Tiempo de Contención (MTTC)

AWS



Justificación e Impacto del Proyecto

Contexto Global

Datos Duros del Sector (2025)

2,508 ciberataques semanales en promedio por institución educativa (Check Point Research).

68% de las universidades fueron víctimas de Ransomware, con un 44% de accesos vía SSO (Sophos).

Comunidad Universitaria

Relevancia Institucional y Social

Garantiza la continuidad formativa de **25,000 estudiantes** y salvaguarda de forma estricta los expedientes académicos así como las pasarelas de pago de colegiaturas de la institución.

Cumplimiento Regulatorio

Marco Legal y Regulatorio

Asegura el cumplimiento obligatorio de los **Artículos 19 y 20 de la LFPDPPP** ante brechas de datos personales (evitando multas del INAI) y preserva la cadena de custodia bajo el **Código Penal Federal**.

Modernización Tecnológica

Factor Innovador

Transición disruptiva desde manuales estáticos y obsoletos hacia **playbooks** dinámicos y automatizados ejecutados en la infraestructura cloud nativa de **AWS**.

Objetivos del Proyecto

Objetivo General

Diseñar un **Plan de Respuesta a Incidentes (IRP)** especializado ante amenazas cibernéticas críticas para la plataforma LMS Canvas y los servicios de autenticación SSO en la Universidad Digital de las Américas (UDA).

Objetivo Específico 01

Diagnóstico y Modelado

Identificar vectores de ataque de alta criticidad y puntos de vulnerabilidad técnica en la arquitectura cloud de soporte (Canvas y SSO).

Objetivo Específico 02

Gobernanza y Automatización

Establecer los **playbooks** tácticos de contención y la estructura formal de gobernanza para el equipo de respuesta ante brechas en cuentas maestras e infraestructura de red.

Fundamentación Teórica y Marco Normativo

Metodología Base

NIST SP 800-61 r2

Ciclo de vida estandarizado en 4 etapas: 1) Preparación, 2) Detección y Análisis, 3) Contención, Erradicación y Recuperación, 4) Actividad Post-incidente.

Gobernanza y Control

ISO/IEC 27001

Alineación de procesos organizacionales para la gestión sistemática del riesgo de seguridad de la información y auditoría continua.

Resiliencia Cloud

AWS Best Practices

Aplicación de patrones de arquitectura elástica, filtrado perimetral avanzado con **AWS WAF** y automatización **serverless**.

Cumplimiento y Ética

Marco Legal y Forense

LFPDPPP (Art. 19 y 20): Notificación de brechas.

Código Penal Federal: Cadena de custodia digital.

Ética Profesional: Cánones de (ISC)² y ACM/IEEE.

Diagnóstico Situacional y Causa Raíz

Análisis FODA

Fortaleza:

Infraestructura nativa en AWS de alta disponibilidad (ALB/EC2) y personal con alta competencia técnica.

Debilidad Crítica:

Inexistencia de un IRP formal, respuestas reactivas y ausencia de playbooks o matriz de escalación.

Causas Raíz

Métodos:

Falta de flujos estandarizados y reglas de filtrado manuales IP por IP.

Organización:

Ambigüedad en la cadena de mando y dudas sobre la autoridad para aislar subredes en crisis.

Entorno:

Exposición pública permanente (24/7) de los endpoints del portal SSO.

Hallazgo Principal

45 a 90

Minutos de retraso

Tiempo de coordinación inicial solo para evaluar anomalías debido a cuellos de botella burocráticos y falta de protocolos probados.

Propuesta de Intervención (Arquitectura del IRP)

Estrategia Integral

Transición de un modelo reactivo e improvisado hacia una defensa proactiva, estructurada y automatizada bajo el estándar **NIST SP 800-61 r2**.

01

Gobernanza y Escalación

Delimitación de **4 niveles de severidad** y establecimiento de una cadena de mando clara entre el Blue Team, el CISO y la Rectoría para eliminar los cuellos de botella burocráticos.

02

Automatización Serverless

Desarrollo de playbooks tácticos con scripts en **Python (Boto3)** en **AWS Lambda** para el aislamiento inmediato de subredes y revocación masiva de tokens SSO.

03

Filtrado Perimetral

Integración de reglas inteligentes en **AWS WAF + CloudWatch** para la mitigación automática de inundaciones de tráfico (DDoS) y telemetría de red en tiempo real.

Plan de Acción y Ejecución

Estructura Operativa del Plan

Ruta de implementación crítica con hitos y entregables definidos para la respuesta a incidentes.

01

Acción 1

Formulación del marco de gobernanza, políticas de comunicación de crisis y matriz de escalación con 4 niveles de severidad.

Fecha límite: 15 de septiembre de 2026

02

Acción 2

Diseño y validación de playbooks tácticos con flujos de contención automatizados en AWS Lambda para Ransomware y Account Takeover.

Fecha límite: 30 de septiembre de 2026

03

Acción 3

Configuración de reglas elásticas de filtrado perimetral en AWS WAF y telemetría de alerta en AWS CloudWatch para mitigación DDoS.

Fecha límite: 15 de octubre de 2026

Presupuesto y Viabilidad Financiera

Inversión Total del Proyecto

\$110,000.00 MXN (Presupuesto global optimizado)

Desglose de Partidas Operativas

\$48,000.00 MXN | **Recursos Humanos Especializados:** 120 horas de ingeniería aplicada (Scripts Lambda, WAF y Matriz).

\$20,000.00 MXN | **Capacitación y Entrenamiento:** Programa práctico de respuesta y simulacro Tabletop Exercise para Blue Team y directiva.

\$13,500.00 MXN | **Infraestructura Cloud (Sandbox):** 3 meses de consumo incremental en AWS para pruebas y retención de logs.

\$22,000.00 MXN | **Validación y Auditoría Externa:** Simulación controlada de intrusión y DDoS por un tercero (evaluación del MTTC).

\$6,500.00 MXN | **Fondo de Contingencia:** Margen operativo para ajustes e imprevistos en la nube (aprox. 6.5%).

ROI

Retorno de Inversión

Viabilidad garantizada al prevenir pérdidas millonarias por:

- Parálisis operativa
- Multas del INAI
- Rescates por extorsión

Resultados Obtenidos y Validación en Sandbox

01

Acción 1: Gobernanza

- **100%** de cumplimiento documental con la matriz aprobada por Rectoría, DTI y Legal.
- **92%** de precisión en toma de decisiones durante el simulacro (Tabletop Exercise).
- Coordinación inicial reducida de 90 min a **8 minutos**.

02

Acción 2: Playbooks Lambda

- Aislamiento automático de instancias EC2 logrando **4.2 minutos** tras la detección (meta <= 15 min).
- Revocación exitosa de sesiones SSO en **1.5 minutos** vía AWS Lambda.

03

Acción 3: Mitigación DDoS

- Mitigación del **98%** de solicitudes maliciosas en un tiempo de **3.5 minutos** con AWS WAF.
- **Cero caídas** en el portal SSO y **0% de falsos positivos** bloqueando tráfico.

Conclusiones

01

Resiliencia y MTTC

La articulación entre gobernanza clara y automatización serverless con AWS Lambda y AWS WAF reduce el Tiempo Medio de Contención de 90 minutos a **menos de 5 minutos**, superando con creces la meta inicial.

02

Certeza Regulatoria

La institución cuenta con protocolos formales que garantizan el cumplimiento de la **LFPDPPP**, mitigando drásticamente el riesgo de sanciones económicas por parte del **INAI** ante brechas de datos personales.

03

Blindaje del SPOF

La protección perimetral del portal SSO asegura la continuidad académica de los **25,000 estudiantes** de la UDA, transformando la ciberseguridad en un habilitador estratégico del modelo EdTech.

Referencias Principales

01

Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). *Computer Security Incident Handling Guide (NIST Special Publication 800-61, Revision 2)*. National Institute of Standards and Technology.

02

Cámara de Diputados del H. Congreso de la Unión. (2010). *Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP)*. Diario Oficial de la Federación.

03

International Organization for Standardization. (2022). Information security, cybersecurity and privacy protection — Information security management systems requirements (ISO/IEC 27001:2022).

04

Amazon Web Services. (2024). *AWS Best Practices for DDoS Resiliency & Security Incident Response Guide*. AWS Whitepapers.

05

Sophos. (2025). *The State of Ransomware in Education 2025*. Sophos Sector Reports.